

Regulatory requirements — CarePath 1.0

Document REQ-CAREPATH-004 · Version 1.1 · Status Approved · Owner Information Governance Lead · Reviewed by Data Protection Officer, 2026-02-12

Demonstration artifact. Synthetic content only — not a clinical record and not a medical device.

This document records which obligations apply, what each one demands of the software, and which control answers it. The control matrix in `07-govern/hipaa-control-matrix.xlsx` carries the evidence.

Applicable

ID	Source	Obligation	What the software must do
REG-01	HIPAA Security Rule §164.312(b), Audit controls	Record and examine activity in systems containing electronic protected health information	Every access to a patient record writes an immutable audit event naming actor, action, purpose and time (NFR-03, NFR-09)
REG-02	HIPAA §164.312(a)(2)(i), Unique user identification	Assign a unique name or number for identifying and tracking user identity	Each principal carries a unique subject identifier; that identifier, never the credential, is what lands in the audit trail
REG-03	HIPAA §164.502(b), Minimum necessary	Limit disclosure to the minimum necessary for the purpose	Role-based access; a caller entitled to know a patient exists is not thereby entitled to their contact details
REG-04	HIPAA §164.312(e)(1), Transmission security	Guard against unauthorised access to data in transit	TLS 1.2 or above terminated at the ingress; no plaintext listener
REG-05	HIPAA §164.312(a)(2)(iv), Encryption at rest	Encrypt electronic protected health information where reasonable	Volume-level encryption on the database host; key management by the platform team
REG-06	UK GDPR Art. 9 / Art. 30	Special-category data requires a lawful basis and a record of processing	Consent decisions recorded per purpose and consulted before disclosure (BR-05); the processing record is maintained by Information Governance
REG-07	HL7 FHIR R4	Exchange in a recognised standard	Export conforms to base FHIR R4 resource definitions for Patient, Encounter and Observation
REG-08	UK GDPR Art. 17 / Art. 20	Erasure and portability on request	Portability is served by the FHIR export. Erasure is a documented manual procedure — see the caveat below

Deliberately not applicable

Source	Why not
IEC 62304 (medical device software lifecycle)	CarePath ranks a worklist; it does not diagnose, treat or recommend a clinical action. The risk score is an operational prioritisation aid and is presented as such. If a future release makes a clinical recommendation, this determination is void and the product becomes a Class I device at minimum

Source	Why not
21 CFR Part 11	No electronic signatures, no submissions to a regulator
PCI DSS	No payment card data is held or processed
US Core profiles	Aspirational, not claimed. Claiming conformance means passing the US Core validator, and release 1.0 does not run it. See ADR-0004

Known regulatory gaps at release 1.0

Recorded here rather than omitted, because an undocumented gap is the one that surfaces during an inspection.

Gap	Obligation	Position	Owner	Target
G-01	REG-08, erasure	No automated erasure. A request is served by a manual database procedure executed by two named engineers under change control. Audit events are exempt from erasure under the retention obligation in NFR-09	Information Governance	Release 2.0
G-02	REG-05	Encryption is volume-level, not column-level. A database administrator with host access can read patient rows. Mitigated by access control and by logging administrative sessions	Platform	Release 2.0
G-03	REG-06	Consent is recorded per purpose but the pilot's lawful basis for direct care is legitimate interest, not consent. The consent record governs <i>disclosure to partners</i> only, and the interface must not imply otherwise	Information Governance	Accepted for 1.0
G-04	REG-07	The export is validated against base FHIR R4 structure definitions by review only. No automated validator runs in the pipeline	Engineering	Release 1.1